

Anhang A11 — Schnittstellenübersicht (OpenAPI 3.0) **Projekt:** Zero-Trust-Sicherheitskonzept mit GitHub-Integration **Version:** 1.0 | **Datum:** 09.07.2026 **Base URL:** `https://api.vfb-bildung.de/api/v1` (Produktion) / `http://localhost:4000/api/v1` (Dev) ---

OpenAPI 3.0 Spezifikation (YAML) ```yaml openapi: 3.0.3 info: title: Zero-Trust RBAC API version: 1.0.0 description: | REST API für automatisierte Rechtevergabe mit GitHub-Integration. Self-Service-Portal, Genehmigungsworkflows, Audit-Logging. contact: name: Daniel Massa email: daniel.massa@vfb-bildung.de license: name: Proprietary (VFB-intern) servers: - url: https://api.vfb-bildung.de/api/v1 description: Produktion - url: http://localhost:4000/api/v1 description: Entwicklung security: - BearerAuth: [] components: securitySchemes: BearerAuth: type: http scheme: bearer bearerFormat: JWT schemas:

User **User:** type: object properties: id: type: string format: uuid azureAdId: type: string email: type: string format: email fullName: type: string department: type: string isActive: type: boolean createdAt: type: string format: date-time #

Role **Role:** type: object properties: id: type: string format: uuid name: type: string description: type: string isSystemRole: type: boolean permissions: type: array items: \$ref: '#/components/schemas/Permission' Permission: type: object properties: id: type: string format: uuid name: type: string resource: type: string action: type: string enum: [read, write, admin, manage] scope: type: string #

Request **RoleRequest:** type: object required: [roleId, reason] properties: roleId: type: string format: uuid reason: type: string minLength: 10 maxLength: 1000 resource: type: string description: Optional spezifische Ressource (Repo, Team, etc.) RoleRequestResponse: allOf: - \$ref: '#/components/schemas/RoleRequest' - type: object properties: id: type: string format: uuid status: type: string enum: [pending, approved, rejected, escalated] requestedAt: type: string format: date-time requester: \$ref: '#/components/schemas/User' role: \$ref: '#/components/schemas/Role' #

Approval **ApprovalInput:** type: object required: [requestId, decision] properties: requestId: type: string format: uuid decision: type: string enum: [approve, reject] rejectionReason: type: string maxLength: 500 #

Audit Log **AuditLogEntry:** type: object properties: id: type: integer timestamp: type: string format: date-time user: \$ref: '#/components/schemas/User' action: type: string enum: [REQUEST, APPROVE, REJECT, GRANT, REVOKE, POLICY_CHECK, EXPORT] resourceType: type: string resourceId: type: string format: uuid result: type: string enum: [success, failed, pending] details: type: object currentHash: type: string pattern: '^[a-f0-9]{64}\$' AuditLogFilter: type: object properties: from: type: string format: date to: type: string format: date userId: type: string format: uuid action: type: string resourceType: type: string page: type: integer default: 1 pageSize: type: integer default: 50 maximum: 500 ExportRequest: type: object properties: format: type: string enum: [csv, json] default: csv from: type: string format: date to: type: string format: date #

Error **ErrorResponse:**

type: object properties: error: type: string message: type: string details: type: array items:
type: string paths: # — Health

/health: get:
summary: Health Check responses: '200': description: Service verfügbar content: application/
json: schema: type: object properties: status: type: string enum: [ok] timestamp: type: string
format: date-time # — Authentication

/auth/login: post: summary:
SSO-Callback (Azure AD SAML/OIDC) requestBody: required: true content: application/x-
www-form-urlencoded: schema: type: object properties: SAMLResponse: type: string
responses: '200': description: Login erfolgreich, Session Cookie gesetzt '401': \$ref: '#/
components/responses/Unauthorized' /auth/logout: post: summary: Logout responses: '200':
description: Abgemeldet # — Current User

/me: get: summary:
Aktueller Nutzer mit Rollen security: - BearerAuth: [] responses: '200': description:
Nutzerdaten content: application/json: schema: allOf: - \$ref: '#/components/schemas/User' -
type: object properties: roles: type: array items: \$ref: '#/components/schemas/Role' # —
Roles Catalog — /roles: get:
summary: Alle verfügbaren Rollen security: - BearerAuth: [] responses: '200': description:
Rollen-Katalog content: application/json: schema: type: array items: \$ref: '#/components/
schemas/Role' # — Requests

/requests: post:
summary: Rollenantrag stellen security: - BearerAuth: [] requestBody: required: true content:
application/json: schema: \$ref: '#/components/schemas/RoleRequest' responses: '201':
description: Antrag erstellt content: application/json: schema: \$ref: '#/components/schemas/
RoleRequestResponse' '400': \$ref: '#/components/responses/BadRequest' '401': \$ref: '#/
components/responses/Unauthorized' get: summary: Eigene Anträge (paginiert) security: -
BearerAuth: [] parameters: - name: page in: query schema: type: integer default: 1 - name:
pageSize in: query schema: type: integer default: 20 - name: status in: query schema: type:
string enum: [pending, approved, rejected, escalated] responses: '200': description: Liste
eigener Anträge content: application/json: schema: type: object properties: data: type: array
items: \$ref: '#/components/schemas/RoleRequestResponse' pagination: type: object
properties: page: type: integer pageSize: type: integer total: type: integer totalPages: type:
integer /requests/{id}: get: summary: Einzelnen Antrag abrufen security: - BearerAuth: []
parameters: - name: id in: path required: true schema: type: string format: uuid responses:
'200': description: Antragsdetail content: application/json: schema: \$ref: '#/components/
schemas/RoleRequestResponse' '404': \$ref: '#/components/responses/NotFound' # —
Approvals — /approvals:
post: summary: Antrag genehmigen oder ablehnen security: - BearerAuth: [] requestBody:
required: true content: application/json: schema: \$ref: '#/components/schemas/
ApprovalInput' responses: '200': description: Genehmigung verarbeitet content: application/
json: schema: type: object properties: requestId: type: string format: uuid decision: type:
string enum: [approved, rejected] processedAt: type: string format: date-time '400': \$ref: '#/

components/responses/BadRequest' '403': \$ref: '#/components/responses/Forbidden' '404':
\$ref: '#/components/responses/NotFound' # — Audit Logs

———— /audit-logs: get:

summary: Audit-Logs abrufen (Admin only) security: - BearerAuth: [] parameters: - \$ref: '#/
components/parameters/AuditLogFilter' responses: '200': description: Audit-Logs content:
application/json: schema: type: object properties: data: type: array items: \$ref: '#/
components/schemas/AuditLogEntry' pagination: type: object properties: page: type: integer
pageSize: type: integer total: type: integer parameters: - name: from in: query schema: type:
string format: date - name: to in: query schema: type: string format: date - name: userId in:
query schema: type: string format: uuid - name: action in: query schema: type: string - name:
page in: query schema: type: integer default: 1 - name: pageSize in: query schema: type:
integer default: 50 # — Export

———— /export: post:

summary: Audit-Logs exportieren (CSV/JSON) security: - BearerAuth: [] requestBody:
required: true content: application/json: schema: \$ref: '#/components/schemas/
ExportRequest' responses: '200': description: Export-Datei content: text/csv: schema: type:
string application/json: schema: type: array items: \$ref: '#/components/schemas/
AuditLogEntry' '401': \$ref: '#/components/responses/Unauthorized' # — Admin: Role

Management ————— /admin/roles: get: summary:

Alle Rollen (Admin) security: - BearerAuth: [] responses: '200': content: application/json:
schema: type: array items: \$ref: '#/components/schemas/Role' post: summary: Neue Rolle
anlegen security: - BearerAuth: [] requestBody: content: application/json: schema: type:
object required: [name, description] properties: name: type: string description: type: string
permissions: type: array items: type: string format: uuid responses: '201': description: Rolle
erstellt /admin/roles/{id}: put: summary: Rolle aktualisieren security: - BearerAuth: []
parameters: - name: id in: path required: true schema: type: string format: uuid responses:
'200': description: Rolle aktualisiert delete: summary: Rolle löschen security: - BearerAuth: []
parameters: - name: id in: path required: true schema: type: string format: uuid responses:
'204': description: Gelöscht # — Admin: GitHub Sync

———— /admin/github/sync: post: summary:

GitHub Teams synchronisieren security: - BearerAuth: [] responses: '200': description: Sync
ausgeführt content: application/json: schema: type: object properties: synced: type: integer
errors: type: array items: type: string # — Common Responses

———— responses: BadRequest:

description: Validierungsfehler content: application/json: schema: \$ref: '#/components/
schemas/ErrorResponse' Unauthorized: description: Nicht authentifiziert content: application/
json: schema: \$ref: '#/components/schemas/ErrorResponse' Forbidden: description: Keine
Berechtigung content: application/json: schema: \$ref: '#/components/schemas/
ErrorResponse' NotFound: description: Ressource nicht gefunden content: application/json:
schema: \$ref: '#/components/schemas/ErrorResponse' ``` --- ## API-Endpunkte Übersicht |
Methode | Pfad | Beschreibung | Auth | Admin | |-----|-----|-----|-----|-----| | `GET` |
`/health` | Health Check | — | — | | | `POST` | `/auth/login` | SSO Login | — | — | | `GET` | `

```

me` | Aktueller User + Rollen | JWT | — || `GET` | `/roles` | Rollen-Katalog | JWT | — ||
`POST` | `/requests` | Antrag stellen | JWT | — || `GET` | `/requests` | Eigene Anträge | JWT
| — || `GET` | `/requests/{id}` | Antragsdetail | JWT | — || `POST` | `/approvals` |
Genehmigen/Ablehnen | JWT | VG || `GET` | `/audit-logs` | Audit-Logs | JWT |    || `POST`
| `/export` | CSV/JSON Export | JWT |    || `GET` | `/admin/roles` | Alle Rollen | JWT |    ||
`POST` | `/admin/roles` | Rolle anlegen | JWT |    || `POST` | `/admin/github/sync` | GitHub
Sync | JWT |    | --- ## Fehlermeldungen (Standard) ```json { "error":
"VALIDATION_ERROR", "message": "Eingabevalidierung fehlgeschlagen", "details": [ "roleId
is required", "reason must be at least 10 characters" ] } ``` --- *Ende Anhang A11.
Vollständige OpenAPI-Spec in `A11_openapi.yaml` im Repository.*

```